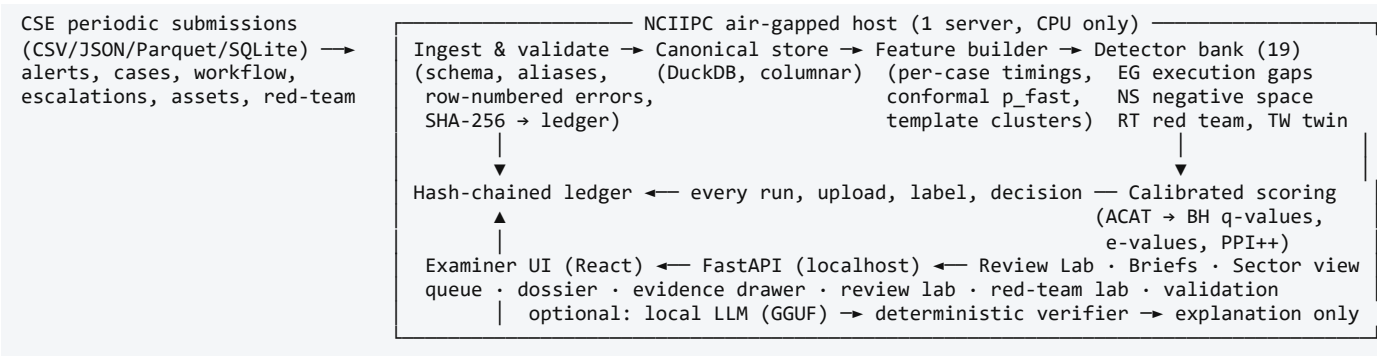


SAT-SA: Solution Architecture

Supervisory Analytics Tool for SOC Assessment, SIH 2026 PS SIH26157 (NTRO/NCIIPC). Offline, regulator-side, evidence-first.

1. Solution architecture



2. Functional design

Function (PS §4)	How SAT-SA delivers it
Ingest periodic SOC data	Multi-format upload with a validation report. Commit merges the submission and re-runs the analysis in the background, then switches over atomically; examiner state is kept.
Execution gaps	EG1 fast closure, EG2 no escalation, EG3 template notes, EG4 no investigation, EG5 workflow non-conformance, EG6 SLA bunching, EG7 recurrence, EG11 24×7 claim, EG12 CERT-In 6 h, EG13 threat intel unused, TW1 twin divergence
Negative space	NS1 silent critical assets, NS2 quiet tactics, NS3 blind tactics, NS5 detection-rule decay, NS7 missing records, NS8 retention gap, NS9 clock faults, RT1 red-team known-positive misses
Peer comparison, risk indicators, prioritisation	A robust peer baseline per detector; an entity p-value by ACAT; BH queue at a chosen FDR ; a 0–100 attention index; a capability radar; sector and provider (MSSP) views
Sample prioritisation	Review Lab: uniform random cases (for a valid estimate) plus model-targeted cases (to confirm)
Explainability and reporting	A reason sentence, evidence ids, method and regulation for each finding; drill-down to the case timeline; a printable examination brief answering SEBI CSCRF questions from evidence; trends, quarterly evidence, survival curves

3. Analytics methodology

- **Calibrated tests.** Rates use a beta-binomial model against peers:
 - over-dispersion is estimated robustly from peers, with a finite-peer variance inflation;
 - mid-p is used for discrete counts;
 - where case mix matters, the test is standardised by severity × verdict (like a hospital standardised mortality ratio).
- **Fast closure.** A leave-one-entity-out conformal p-value within (severity × alert type).
- **Silence.** Negative-binomial tests vs peer asset classes and the asset's own history.
- **SLA gaming.** A bunching estimator (polynomial counterfactual) with a random-effects empirical null that includes the fit variance.
- **Twin.** Synthetic control (non-negative weights over peers) with placebo inference.
- **Combination.** Cauchy combination (ACAT, valid under dependence), then **Benjamini–Hochberg**: of the flagged entities, at most the chosen share (default 10%) is expected to be false alarms.
- **Anytime-valid monitoring.** Quarterly e-values multiplied into an e-process with e-BH, so repeated looks do not inflate false alarms.
- **Prediction-powered inference (PPI+).** Examiner labels on a random sample plus model predictions on all other cases give a valid interval for the true share of superficial handling, with fewer reviews. A Wilson-regularised variance prevents the collapse the plain interval suffers on rare outcomes.
- **Provider effect.** A random-effects (DerSimonian–Laird) provider shift, in percentage points with a CI.
- **Deterministic lane.** Blind tactics, clock faults, retention gaps and red-team misses are documented facts. They are shown separately and never mixed into the statistics.

4. AI / ML components (PS §5)

	Superficial-handling predictor (core)	Explanation assistant (optional)
Architecture	Logistic regression on 11 case features (conformal speed, investigation steps, templated note, escalation, IOC, ...)	Qwen3-4B-Instruct-2507, 4-bit GGUF, run by llama.cpp (llama-cpp-python)
Hardware	Any CPU; trains in < 1 s	4-core CPU, 4 GB RAM for the model; about 1–2 min per explanation (pre-generated for the queue)
Offline training / inference	Trained locally on examiners' earlier verdicts (simulated in the demo); inference in-process	Pre-trained open weights, copied once; no internet, no API; grammar-constrained JSON output

	Superficial-handling predictor (core)	Explanation assistant (optional)
Update mechanism	Retrained each cycle from new examiner labels; model hash in the run record	Replace the GGUF file (weights hash recorded); no fine-tuning needed
Explainability controls	Coefficients are readable. The model never flags anyone : it only targets review samples and powers PPI, which stays valid even if the model is poor.	Each claim must cite records in the evidence pack, quote them verbatim and use only numbers present there. Claims that try to clear the entity are rejected. Entity-written notes are fenced as untrusted, and instruction-like text is flagged and never used as evidence .
Auditability controls	Run hash = hash(input data, code, seed), written to the ledger	Every explanation is ledgered (mode, verified and rejected counts); rejected claims are shown to the examiner

5. Data requirements

- **Required:** alerts (id, asset, time, category, severity, rule), cases (id, alert, severity, opened/ack/closed, escalated, notes), workflow events, escalations and reports, asset inventory with criticality, and monthly submission receipts.
- **Optional, improves specific detectors:** verdict, remediation, IOC enrichment, SOAR flag, declared log sources, red-team reports.
- About 12 months of history per entity is needed for the twin and decay detectors; everything else works from one quarter.

6. Validation methodology (PS §8)

1. **Planted weaknesses** on independently seeded panels with a hidden answer key. Recall is 100% at 10% FDR over 5 seeds; hard negatives are never flagged.
2. **False-alarm calibration** on 40 all-healthy panels: 5% realised at a 10% promise. Over four quarterly looks, naive re-testing reaches 55% while e-BH stays at 2.5%. **On real data:** 1,286 GUIDE organisations randomly re-split, 5%.
3. **Against expert manual review** (Microsoft GUIDE, 499 real SOC queues ranked by experts). SAT-SA's targeted sampler puts expert top-20 incidents in **84%** of the first 10 reviews, against 14% for random sampling. PPI intervals on real analyst verdicts cover 98% of the time.
4. **Versus manual sampling at an equal budget:** 55 vs 7 superficial cases found per 100 reviews.
5. **Adversarial:** a gaming simulator (7 strategies × 5 audit policies), a power curve for subtle weaknesses, and reproducibility (identical hashes on re-run).

In deployment: examiners' dispositions on flagged findings, plus a small uniform-random floor of reviews on *unflagged* entities, give a running precision and miss-rate estimate each cycle.

7. Infrastructure, deployment and operations

- **Hardware.** One server: 8 cores, 16–32 GB RAM, 50 GB SSD. The demo runs on a 4-core laptop: 453k alerts and 215k cases are analysed in about 3 min with 1.3 GB RAM.
 - DuckDB is columnar and embedded, and scales to hundreds of entities on one host.
 - Scale-out means partitioning by sector.
- **Software.** Python 3.11+, with permissive-licence dependencies only (no GPL/AGPL). A pre-built web UI is served locally.
- **Install.** A wheelhouse with a SHA-256 manifest is installed offline (`install_offline.bat`). There are no cloud, SaaS or external model dependencies, and a test verifies analysis with all network sockets blocked.
- **Security of the tool.**
 - Binds to localhost by default.
 - Submission files are hashed.
 - The append-only hash-chained ledger has a verifiable head.
 - Untrusted text is never executed or obeyed.
- **Operating cycle:** CSE submits → validate and commit → analysis (minutes) → queue review → sampling and dispositions → brief exported → ledger head archived.

8. What is new (vs rule thresholds and anomaly scores)

- **A promise the regulator can defend:** "at most 10% of this queue are false alarms". This is verified on healthy panels and on real organisations, not asserted.
- **Fewer manual reviews with valid confidence:** prediction-powered inference, which stays valid even when the model is wrong.
- **Negative space made measurable:** *blind* (cannot see) is separated from *quiet* (sees, nothing fired); detection-rule decay; red-team known-positive misses.
- **Gaming-aware:** SLA bunching, a synthetic twin, anytime-valid re-checks, and a simulator showing which audit policies a SOC can game.
- **Real expert labels:** validated against expert queue rankings from 499 real SOC queues.
- **Safe AI:** optional, local, verifier-gated, and resistant to prompt injection in submitted notes. It never decides.